

Cloud Security - Laboratório 2 - Quem está mexendo aqui?

AWS Config: Identificando recursos mal configurados

- 1) Navegue até o serviço Config. Observe o Dashboard e identifique os dados exibidos
- 2) Acesse o menu "Rules" e observe as regras gerenciadas e customizadas
- 3) Agora acesse o menu "Resource" e observe os recursos listados. Busque o recurso VPC
- 4) Dentro do recurso, identifique as alterações por meio do Resource Timeline. Como é possível identificar recursos que não estão configurados corretamente?

GuardDuty: Identificação de Ameaças

- 1) Acesse o serviço GuardDuty. Observe o dashboard.
- 2) Navegue pelos findings, o que é possível detectar? Consegue identificar os diferentes tipos de findings?
- 3) Na sua visão, em quais cenários o GuardDuty pode ajudar?

SecurityHub: Centralizar findings e priorizar tarefas

- 1) Acesse o serviço SecurityHub. O que pode ser observado no dashboard?
- 2) Acesse os padrões de segurança. Se você precisasse explicar o conceito dos padrões de para o seu gerente, como explicaria?

Simulação de exfiltração de dados

Neste exercício vamos simular o cenário descrito no slide apresentado em aula. Para isso vamos emular uma aplicação com uma vulnerabilidade e vamos explorar essa vulnerabilidade para extrairmos dados sensíveis de uma conta AWS. É claro que tudo é uma simulação e o conhecimento adquirido aqui serve apenas para fins educacionais e **NUNCA** devem ser aplicados para fins maliciosos.

Parte 1 – Fazendo o deploy de uma aplicação da empresa no ambiente cloud da AWS

Crie um bucket e insira um arquivo de texto com dados fictícios dentro dele (algo como segredos.txt);

Inicie a criação de uma EC2 Amazon Linux 2023 – t3.micro;

Não é necessário um keypair;

Na configuração de Security Group, libere a porta TCP 8080 apenas para o seu próprio IP;

Garanta que a instância tenha um IP público;

Em Advanced Details:

Selecionar em IAM Instance Profile > "LabInstanceProfile";

Em "Metadata Version", selecione "V1 and V2";

Acesse o seguinte arquivo: <https://github.com/erik-etsushi/labs/blob/main/security/user-data-amzn-linux>

Copie o conteúdo completo do arquivo e cole-o na seção "User Data";

Inicie a instância;

Aguarde alguns minutos e tente acessar http://<<EC2_PUBLIC_IP>>:8080

Esta é uma aplicação vulnerável a um ataque de Server Side Request Forge (SSRF);

Parte 2 – Tentado extrair os dados sensíveis da empresa a partir do seu notebook particular

Aqui vamos simular o notebook de um atacante. É importante que você tenha o AWS CLI instalado na sua máquina. Se não tem, acesse a URL: <https://docs.aws.amazon.com/cli/latest/userguide/getting-started-version.html>

Vamos iniciar a tentativa de acesso: acesse a aplicação http://<<EC2_PUBLIC_IP>>:8080

Relembre o conceito apresentado no slide e tente extrair os metadados da instância (Access Key, Secret Access Key, Session Token) por meio da aplicação vulnerável;

Assim que conseguir os metadados de acesso privado (Access Keys, Secret Access Key, Session Token), reconfigure a sua AWS CLI para usar as credenciais extraídas da aplicação: aws configure

Em seguida verifique se o caminho está livre na linha de comando: aws sts get-caller-identity

Se a resposta vier correta, com a identificação da role correta, você pode extrair os dados do bucket:

Primeiro verifique os buckets disponíveis: aws s3 ls

Depois copie o arquivo secreto para a sua máquina local: aws s3 cp s3://meu-bucket-super-secreto-lab/segredos.txt .